

MITM Attacks on HTTPS: Another Perspective

MITM Attacks on HTTPS: Another Perspective - GreenD0g, Slideshare.

- Published: 2017-11-20
- Original: <<https://www.slideshare.net/GreenD0g/mitm-attacks-on-https-another-perspective/>>
- Current location: <<https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614>>
- Preserved from: <https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614> (live) on 2026-08-06
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

- [1 / 43

](<https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#1>)

- [2 / 43

](<https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#2>)

- [3 / 43

](<https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#3>)

- [4 / 43

](<https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#4>)

- [5 / 43

](<https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#5>)

- [6 / 43

](<https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#6>)

- [7 / 43

](<https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#7>)

- [8 / 43

](<https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#8>)

- [9 / 43

](https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#9)

- [10 / 43

](https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#10)

- [11 / 43

](https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#11)

- [12 / 43

](https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#12)

- [13 / 43

](https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#13)

- [14 / 43

](https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#14)

- [15 / 43

](https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#15)

- [16 / 43

](https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#16)

- [17 / 43

](https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#17)

- [18 / 43

](https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#18)

- [19 / 43

](https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#19)

- [20 / 43

](https://www.slideshare.net/slideshow/mitm-attacks-on-https-another-perspective/82373614#20)

[image: © Digital Security MITM Attacks on HTTPS: Another Perspective Alexey GreenDog Tyurin @antyrin]

[image: © Digital Security 2 MITM Attacks on HTTPS: Another Perspective About me • Pentester • Security researcher • WEB/Java/Network security fun • EasyHack for "Xakep" • Co-organizer ZeroNights • Co-organizer Defcon Russia 7812]

![@ Digital Security 3 MITM Attacks on HTTPS: Another Perspective HTTPS • TLS (SSL)+ HTTP • Protects against man-in-the-middle attacks • Authentication, Encryption, Integrity – Silver bullet ? • Crypto attacks:

- POODLE, BEAST, CRIME... Hard to exploit](https://image.slidesharecdn.com/httpschecked-171120115606/85/MITM-Attacks-on-HTTPS-Another-Perspective-3-320.jpg)

[image: © Digital Security 4 MITM Attacks on HTTPS: Another Perspective TLS specifics • Knows nothing including protocol: HTTP/SMTP/POP3/TDS/...+TLS TLS HTTP]

[image: © Digital Security 5 MITM Attacks on HTTPS: Another Perspective TLS specifics • Application layer • Knows nothing about underlying protocol • Doesn't protect against destination changing (IP, port) | P TCP TLS HTTP]

[image: © Digital Security 6 MITM Attacks on HTTPS: Another Perspective TLS specifics • Authentication using x509 certificates • Client compares server name and SAN field of certificate]

[image: © Digital Security 7 MITM Attacks on HTTPS: Another Perspective Certificates features and limitations • Doesn't care about port (many services – 1 certificate) • For a wide range of domain names: • Many names in SAN - Subject Alternative Name (+ CN*) • Wildcard certificate • No SNI • TLS cache * • *HTTP/2 connection sharing* * Since 58, Chrome doesn't check CN, only SAN (because of RFC) * <http://antoine.delignat-lavaud.fr/doc/www15.pdf>]

[image: © Digital Security 8 MITM Attacks on HTTPS: Another Perspective Wildcard names]

[image: © Digital Security 9 MITM Attacks on HTTPS: Another Perspective A lot of names in SAN]

[image: © Digital Security 10 MITM Attacks on HTTPS: Another Perspective TLS Redirection • Group of MitM attacks – misuse of authentication limits and features • Any protocol • Virtual host confusion (<http://antoine.delignat-lavaud.fr/doc/www15.pdf>)]

[image: © Digital Security 11 MITM Attacks on HTTPS: Another Perspective Simplest example • Attacker (A) controls files on HostB • A. uploads own new_version.exe on HostB • Autoupdate on Victim (V) requests a new version of software: https://www.correct.com/new_version.exe • A. MitMs and redirect to HostB • Autoupdate downloads and runs A's exe file]

[image: © Digital Security 12 MITM Attacks on HTTPS: Another Perspective Requirements • HostA and HostB have different IP (or ports) • HostB has an x509 certificate with the domain name of HostA in SAN]

[image: © Digital Security 13 MITM Attacks on HTTPS: Another Perspective Requirements • Depends on a situation: • When a request for HostA comes to HostB, there is no such a value in virtual hosts of HostB webserver, HostB serves default domain.]

[image: © Digital Security 14 MITM Attacks on HTTPS: Another Perspective Requirements • A. controls something in user's requests or server's responses]

[image: © Digital Security 15 MITM Attacks on HTTPS: Another Perspective Level of control What can A. control with the help of a server's response (with focus on HTTPS): • Nothing • Parts of response (some values in body) • Full body of a specific URL. • Full body of any URL. • Full control (header, body) w/o access to TLS key.]

![@ Digital Security 16 MITM Attacks on HTTPS: Another Perspective Common example – XSS XSS on HostB (Part of body)

1. V. request to HostA + xss of HostB

https://www.correct.com/xss_of_hostb_here

1. A. MitMs and changes an IP

2. HostB responses with A's JS

3. V. executes JS (context of HostA)

4. A. stops the MitM attack

5. JS can interact with HostA in a usual

way Browser knows nothing about MitM!](https://image.slidesharecdn.com/httpschecked-171120115606/85/MITM-Attacks-on-HTTPS-Another-Perspective-16-320.jpg)

[image: © Digital Security 17 MITM Attacks on HTTPS: Another Perspective Video. XSS]

[image: © Digital Security 18 MITM Attacks on HTTPS: Another Perspective Tricks A. can make injections into any http traffic: • no need to force user to open a link w/ HostB XSS]

[image: © Digital Security 19 MITM Attacks on HTTPS: Another Perspective Tricks A. can make injections into any http traffic: • A. can add HostB's cookies for HostA and exploit XSS of HostB w/ auth (cookie for cing) We can exploit Self-XSS! %P]

[image: © Digital Security 20 MITM Attacks on HTTPS: Another Perspective Flash • Crossdomain.xml allows cross domain interaction HostB: • API server • No cookie • Has crossdomain.xml file with * (or similar) <cross-domain-policy> <allow-access-from domain="*" secure="true"/> </cross-domain-policy> No way to perform an attack?]

![(© Digital Security 21 MITM Attacks on HTTPS: Another Perspective Flash Crossdomain.xml w/ * on HostB (nothing)

1. V. opens A's swf
2. Swf sends request to HostA
3. Flash checks crossdomain.xml
4. A. MitMs and changes an IP
5. HostB responds w/ crossdomain.xml
6. Swf is allowed to interact w/ HostA
7. A. stops the MitM attack
8. SWF can interact with HostA in a

usual way](https://image.slidesharecdn.com/httpschecked-171120115606/85/MITM-Attacks-on-HTTPS-Another-Perspective-21-320.jpg)

[image: © Digital Security 22 MITM Attacks on HTTPS: Another Perspective Cross protocol - IE Text-based service that reflects requests on HostB • SMTP, POP3, IMAP, etc • Browser - Internet Explorer • Old school attack • HTTP/0.9 • Content-Sniffing (.html) • Port restriction – doesn't work, It's MitM]

[image: © Digital Security 23 MITM Attacks on HTTPS: Another Perspective Cross protocol - IE Text-based service that reflects requests on HostB • SMTP, POP3, IMAP, etc • Browser - Internet Explorer • Old school attack • HTTP/0.9 • Content-Sniffing (.html) • Port restriction – doesn't work, It's MitM]

![(© Digital Security 24 MITM Attacks on HTTPS: Another Perspective Cross protocol - IE

1. V. sends the POST request w/ JS payload to "any_url.html on" to HostA

1. A. MitMs and changes an IP
2. HostB reflects the request
3. IE interprets it as HTTP/0.9
4. ".html" forces IE to parse as html
5. V. executes JS (in the context of HostA)

6. A. stops the MitM attack

7. JS can interact with HostA in a usual way](<https://image.slidesharecdn.com/httpschecked-171120115606/85/MITM-Attacks-on-HTTPS-Another-Perspective-24-320.jpg>)

[image: © Digital Security 25 MITM Attacks on HTTPS: Another Perspective Video. Cross protocol - IE]

![@ Digital Security 26 MITM Attacks on HTTPS: Another Perspective Cross protocol – Other browsers (FF, Chrome) A. wants to steal Basic Auth header or HttpOnly cookie A. has XSS on HostA (can execute JS in it's context) (Nothing)

1. JS sends a request to HostA
2. A. MitMs and changes IP
3. HostB reflects the request

-Browser interprets it as HTTP/0.9, text/plain

- JS is allowed to read response (same origin)](<https://image.slidesharecdn.com/httpschecked-171120115606/85/MITM-Attacks-on-HTTPS-Another-Perspective-26-320.jpg>)

![@ Digital Security 27 MITM Attacks on HTTPS: Another Perspective JavaScript +DOM Web app w/ JQuery uses load() to get content Text-based service that reflects requests on HostB (Nothing) or file uploading is possible

1. A. sets a cookie w/ xss on HostA (cookie forcing)

Set-Cookie: test=<script src="...">

1. V. opens HostA. JQuery is loaded.
2. For other requests load() is used
3. load sends a request to HostA
4. A. MitMs and changes an IP
5. HostB reflects the request

-Browser interprets it as HTTP/0.9, text/plain

- JQuery.load parses it and execute our XSS payload
- Our JS can interact with HostA in a usual way](<https://image.slidesharecdn.com/httpschecked-171120115606/85/MITM-Attacks-on-HTTPS-Another-Perspective-27-320.jpg>)

![@ Digital Security 28 MITM Attacks on HTTPS: Another Perspective REST API V. is a web app that checks auth (for 200 OK) using HostA REST API Text-based service that reflects requests on HostB (Nothing) or it returns 200 OK for any requests

1. A. tries to auth on V
2. V. sends request to HostA to check auth
3. A. MitMs and changes an IP
4. HostB reflects all the request
5. Curl interprets it as HTTP/0.9 *
6. Curl returns CURLE_OK
7. A. is authenticated

8. <https://github.com/curl/curl/issues/467>](<https://image.slidesharecdn.com/httpschecked-171120115606/85/MITM-Attacks-on-HTTPS-Another-Perspective-28-320.jpg>)

[image: © Digital Security 29 MITM Attacks on HTTPS: Another Perspective Upload anything A. can upload files on HostB Too simple: • Html w/ xss , SWF, PDF ... (SDRF attack) • Everything is executed in the context of HostA The same attack as in the example with XSS]

[image: © Digital Security 30 MITM Attacks on HTTPS: Another Perspective Active content substitution A. can upload files on HostB, but w/ "uninteresting" Content-Type (text/plain, image/png) or Content-Disposition (any path) Think out of the box: • Page consists of html, external files – JavaScript and CSS • Force downloading JS from another host • <https://hosta/script.js>]

[image: © Digital Security 31 MITM Attacks on HTTPS: Another Perspective Active content substitution • Page consists of html, external files – JavaScript and CSS • Force downloading JS from another host • One TLS for all content?]

![@ Digital Security 32 MITM Attacks on HTTPS: Another Perspective Browsers behavior <script src="script.js"> and headers:

- no browser cares about Content-Disposition header
- IE doesn't care about Content-Type header (without nosniff)
- FF, Chrome, Edge don't execute script only if Content-Type is from

"image" family (without nosniff)

- with X-Content-Type-Options, all the browsers require correct

Content-Type](<https://image.slidesharecdn.com/httpschecked-171120115606/85/MITM-Attacks-on-HTTPS-Another-Perspective-32-320.jpg>)

[image: © Digital Security 33 MITM Attacks on HTTPS: Another Perspective Active content substitution Possible Attacks: • External files is on another web site (<https://static.correct.com/script.js>) – easy for MitM (static.correct.com -> HostB) • Protocol attacks]

[image: © Digital Security 34 MITM Attacks on HTTPS: Another Perspective Active content substitution Possible Attacks: • WPAD • Automatic proxy detection. Windows, by default • Pac file w/ rules • For Chrome, Firefox: different proxies for different URLs • Chrome – patched, FF – will be patched; Windows – partly patched; after BH 2016 □ • Now: Useful only for different sites (and tricks)]

[image: © Digital Security 35 MITM Attacks on HTTPS: Another Perspective Active content substitution Possible Attacks: • Browser's cache misuse • By default, web servers add cache headers to "static" content (javascript, css, etc) • Browser cache is URL-based]

![@ Digital Security 36 MITM Attacks on HTTPS: Another Perspective Active content substitution A. can upload files on HostB, but w/ "uninteresting" Content-Type or Content-Disposition (any path)

1. V. request to HostA + script.js of HostB
2. A. MitMs and changes IP
3. HostB responses with A's JS
4. V. caches JS for url:

<https://hosta/script.js>

- A. stops mitm attack

- A. forces V. to open HostA
- V. parses html from HostA
- But takes script.js from its cache, cause it's there and still fresh
- V. executes JS (in the context of HostA)
- JS can interact with HostA in a usual way](<https://image.slidesharecdn.com/httpschecked-171120115606/85/MITM-Attacks-on-HTTPS-Another-Perspective-36-320.jpg>)

[image: © Digital Security 37 MITM Attacks on HTTPS: Another Perspective Active content substitution]

[image: © Digital Security 38 MITM Attacks on HTTPS: Another Perspective Active content substitution - Trick A. can upload files on HostB, but w/ "uninteresting" Content-Type or Content-Disposition (specific path) How can we manipulate with a path? Depends on technologies • RPO • Default error page w/ relative scripts https://hosta/anything_here/lalala/ -> [anything_here/lalala/script.js](https://hosta/anything_here/lalala/script.js) • IE HostHeader injection • ...]

[image: © Digital Security 39 MITM Attacks on HTTPS: Another Perspective What else? • HTTPS 2 HTTP redirect • Reverse Proxy misrouting (CDNs) • Certificate Pinning • Client Cert auth "bypass" • CSP bypass • Crypto attacks • Another Protocols • ...]

[image: © Digital Security 40 MITM Attacks on HTTPS: Another Perspective Conclusion TLS Redirection • Based on TLS features • Based on your imagination and circumstances • For any protocol (but works best for HTTPS) • Not so hard to exploit • You can get something from nothing (or misuse safe stuff)]

[image: © Digital Security 41 MITM Attacks on HTTPS: Another Perspective Conclusion TLS Redirection • "New" approach of attacking TLS secured protocols • The security level of web service equals to the security level of the weakest service with common certificate • Based on the certificate of the weakest service]

[image: © Digital Security 42 MITM Attacks on HTTPS: Another Perspective Conclusion • Awareness • Need more research • There will be a lot of stuff and tricks - <https://github.com/GrrrDog/TLS-Redirection> Read about Virtual Host Confusion - <https://bh.ht.vc/> - AWESOME STUFF THERE!]

[image: © Digital Security 43 MITM Attacks on HTTPS: Another Perspective Questions www.twitter.com/antyurin a.tyurin@dsec.ru]